

(U) ANNEX I: CLOUD SECURITY GUIDANCE

**Version 5.2
30 June 2018**

(U) Table of Contents

(U) REVISION LOG	v
1.0 (U) INTRODUCTION	1
2.0 (U) GUIDANCE	1
2.1 (U) General Guidance	1
2.2 (U) Securing Virtual Private Cloud (VPC) Environments	2
2.2.1 (U) Restrict Access to Private Subnets/Control VPC Ingress Points:	2
2.2.2 (U) Design for High Availability & Disaster Recovery:	3
2.2.3 (U) Security Monitoring & Auditing:	3
2.2.4 (U) VPC Access & Account Creation:	3
2.2.5 (U) Elastic Load Balancer (ELB):	3
2.2.6 (U) Security Groups & Network Access Control Lists (NACL):	3
2.3 (U) Securing Elastic Compute Cloud (EC2) Instances	4
2.3.1 (U) Security Monitoring and Auditing:	4
2.3.2 (U) Access Control:	4
2.3.3 (U) Data Security:	5
2.3.4 (U) Configuration Management:	5
2.3.5 (U) EC2 Key-Pairs:	5
2.4 (U) AWS Auto Scaling	6
2.5 (U) AWS Trusted Advisor	6
2.6 (U) Securing Cloud Data	6
2.7 (U) Cloud Security Services	7
2.8 (U) Data Encryption	7
2.8.1 (U) Encrypting Data in Transit	7
2.8.2 (U) Encrypting Data at Rest and Key Management	7
2.9 (U) Identity and Access Management	8
2.10 (U) Bastion Host	10
2.11 (U//FOUO) Enterprise Cross Domain Services	10
2.12 (U) Enterprise Audit	11
2.13 (U) Infrastructure Security	11
2.13.1 (U) Chef Utility	11
2.13.2 (U) Puppet Utility	12
2.14 (U) Cloud Incident Response	13
2.15 (U) Patch Management	14
2.16 (U) Host-Based Security Services	14
2.17 (U) Platform Security	14
2.17.1 (U) Securing Containers	14
2.17.2 (U) Securing Pivotal Cloud Foundry	16
2.18 (U) Assessment & Authorization (A&A)	17

Annex I: Cloud Security Guidance

2.19	(U) Risk Management Framework.....	19
2.19.1	(U) Information Impact Level Determination.....	19
2.20	(U) Shared Security Responsibility Model	20
2.20.1	(U) Security Inheritance Model.....	21
2.21	(U) ATO Self-Assessment.....	23
2.21.1	(U) Body of Evidence.....	24
2.22	(U) Risk Evaluation Acceleration Management Process (REvAMP)	24
2.23	(U) DevOps Security	26
2.23.1	(U) Static Application Security Testing (SAST)	27
2.23.2	(U) Dynamic Application Security Testing (DAST)	27
2.23.3	(U) Interactive Application Security Testing (IAST)	28
2.23.4	(U) DevOps Software Security Testing	28

Annex I: Cloud Security Guidance

(U) TABLE OF FIGURES

Figure 1: (U) Auto Scaling Policy	6
Figure 2: (U) Security Templating Process	12
Figure 3: (U) Cloud Transition A&A Process	18
Figure 4: (U) RMF Process	19
Figure 5: (U) REvAMP Risk Evaluation Levels	25
Figure 6: (U) DevOps Pipeline	27
Figure 7: (U) DevOps Software Security Testing Workflow	29
Figure 8: (U) DevOps Software Security Testing Component Relationships	31

(U) LIST OF TABLES

Table 1: (U) Information Impact Level Attributes	20
Table 2: (U) Body of Evidence (A&A) Requirements	24
Table 3: (U) REvAMP (Levels 0-2) Qualification Criteria	25
Table 4: (U) ThreadFix Scanner Integrations with Corresponding Jenkins Plug-ins	30

Annex I: Cloud Security Guidance

(U) REVISION LOG

UNCLASSIFIED		
Version	Revision Date	Revision Summary
1.0	12/31/2015	Initial Release Cloud Security Guidance V1
2.0	02/29/2016	Cloud Security Guidance V2-updated Container Security, DewPoint, Automating Security
3.0	4/19/2016	Cloud Security Guidance V3- update Enterprise Security Services, PCF
4.0	6/30/2016	Cloud Security Guidance V4: DevOps Testing; VPC & EC2 Security
4.1	8/5/2016	Updated classification/portion marking to support push to SBU
5.0	9/30/2016	Added Data Encryption and Key Management
5.2	5/31/2018	Updated Trusted Advisor, Auto Scaling, REvAMP, guidance statements, Cloud Transition Security Process, and Data Encryption

Annex I: (U) Cloud Security Guidance

1.0 (U) INTRODUCTION

(U) The Cloud Security Guidance Annex provides security guidance for all NGA cloud environments on the Top Secret, Secret, and Unclassified domains. This security guidance is to be considered in cloud development, deployment, and operations.

(U) The guidance addresses key security requirements and offers recommended best practices and requirements to programs adopting cloud services. Key overarching concepts of this guidance are:

- Embedding security into development activities (i.e., enterprise services)
- Automating security processes (i.e., infrastructure as code)
- Governing security changes

(U) The document discusses security architecture impacts, as well as aligns the cloud security services with NGA inheritable security controls, processes and policies, and establishes a common terminology for cloud security services and Intelligence Community (IC) compliance standards.

(U) NGA's approach to securing the cloud is to deploy security services that are consistent throughout the enterprise and across all security domains. Security services are focused on the services and tools that integrate or operate with AWS services, given its Cloud Service Provider (CSP) support in all three domains. Exceptions will exist where the security risk, and/or operating environment dictate deviations. Ultimately, the goal is to employ and manage a single baseline of security services that provide the necessary levels of security.

2.0 (U) GUIDANCE

2.1 (U) General Guidance

(U) **Guidance:** *Program Managers and developers will adhere to all NGA/IC applicable security policies.*

(U) This guidance provides software engineers and developers participating in the deployment of NGA services to cloud environments with the essential security requirements and principals drawn from industry best practices. Information on signed and draft policies can be found at:

- [NGA Corporate Policy Library](#)
- [NGA/TSR Reference Library](#)

(U) Also, refer to [AWS Security Best Practices](#) for CSP-related information.

(U) Architects/Designers:

- **Guidance:** *Developers shall leverage APIs to integrate enterprise security services with existing cyber capabilities available in the cloud.*
- **Guidance:** *Instances deployed in the cloud will enforce least privileged access controls.*
- **Guidance:** *Developers shall use layered security concepts to provide isolation between security zones based on data sensitivity—firewall layering, application containers, virtual firewalls.*

- **Guidance:** Applications shall be deployed on authorized enterprise standard Virtual Machine Images (VMIs).
- **Guidance:** Trust boundaries between services and components should be highlighted in architecture patterns by:
 - o Building immutable infrastructure where security is integrated into the infrastructure utilizing approved VMIs that build to an approved baseline.
 - o Leveraging hardening scripts (i.e., Chef recipes) for consistent image deployments.

(U) Administrators/Developers:

- **Guidance:** Standard Virtual Private Network (VPN) protocols such as SSH, SSL and IPSEC shall be employed when deploying virtual private cloud (VPC).
- **Guidance:** Applications shall utilize external trusted security services for authentication and authorization, when possible.
- **Guidance:** Sensitive data will be encrypted at rest to ensure unauthorized access to sensitive data does not occur.
- **Guidance:** Data masking and encryption will be employed based on data sensitivity aligned with enterprise data classification standards.

2.2 (U) Securing Virtual Private Cloud (VPC) Environments

(U) **Guidance:** Secure Virtual Private Clouds (VPCs) shall apply security groups, establish subnets and control inbound and outbound traffic with Network Access Control Lists (NACLs) accesses to resources.

(U) Activities should employ a deny-all traffic by default enforcement policy for their cloud environment; and, only open the minimum necessary ports for the application to function. Administrators should at a minimum adhere to security best practices for VPCs as follows:

2.2.1 (U) Restrict Access to Private Subnets/Control VPC Ingress Points:

- Only instances that should be accessible via the Internet shall reside in public subnets, when Internet access is required for Private Subnets, such traffic is to be routed through a network address translation (NAT) instance in order to prevent direct inbound connections.
- Isolate VPCs according to their corresponding functional areas, including development, testing, and production.
- Control and monitor all outgoing traffic traversing an internet gateway by restricting the ports, domains, URLs, etc.
- Establish VPN connections to the virtual private gateway from gateway devices on premises. Secure each connection with a pre-shared key in conjunction with the IP address of the customer gateway device.

2.2.2 (U) Design for High Availability & Disaster Recovery:

- Continuously backup your environment's image to ensure fast recovery in the event of a system failure.
- Maintain high availability by deploying resources across multiple Availability Zones (AZ) within the same region. If a service disruption occurs in one AZ, traffic can be routed to alternate AZs to limit the impact of the disruption.
- Reduce latency of geographical distant users and contribute to high availability of mission critical systems by deploying resources across multiple regions when available.

2.2.3 (U) Security Monitoring & Auditing:

- Use CloudWatch or the AWS Management Console to monitor the health and performance of the instances running within the VPC, as well as the status of all VPN connections to reduce response time in the case of a disruption.
- Leverage CloudTrail to monitor Access Control Lists (ACL) within the VPC and ensure compliance with policy.
- Configure privileged IAM on the VPC in order to monitor and audit administrator access.
- Enable VPC flow logs to capture packet movement across the VPC.
- Apply anti-virus protection across all EC2 instances.

2.2.4 (U) VPC Access & Account Creation:

- Leverage the bastion host to access private instances within a VPC from an external network.

2.2.5 (U) Elastic Load Balancer (ELB):

- ELBs should only be provisioned for public subnets within the VPC.
- Increase ELB availability for redundancy purposes, given AWS stores ELB replication within one AZ, by periodically storing snapshots in the S3 for long-term durability in case of a service disruption.
- Enable point-to-point encryption using TLS for networks that use HTTPS connections; and, terminate at the ELB level as opposed to the instance level.

2.2.6 (U) Security Groups & Network Access Control Lists (NACL):

- Standardize the security group naming convention to improve management and reduce manual errors.
- Establish unique security groups for each VPC in order to maintain network segmentation.
- Security groups must be created specifically for the VPC, as any EC2 level security group(s) will not be applied within the VPC.
- Restrict access to administrative ports such as 22 (SSH) and 3389 (RDP) to only those IP addresses that absolutely require it. Similarly restrict access to common database ports.

- Avoid creating security groups that apply to port ranges, only create rules that apply to a single port.
- Use non-standard ports for internal application traffic.

(U) As NACLs are only applied to traffic that travels between subnets within the VPC, allow only required ports necessary for application to application communication and close all other unnecessary ports.

2.3 (U) Securing Elastic Compute Cloud (EC2) Instances

(U) **Guidance:** *The Operating System (OS) and applications residing on cloud compute (e.g., EC2) instances will be patched as mandated to keep them secure from known vulnerabilities; Risk Management will enforce patching frequency.*

(U) **Guidance:** *Encryption protocols, such as TLS or IPsec, will be used on all traffic between cloud compute (e.g., EC2) instances.*

(U) **Guidance:** *Activities residing on cloud compute (e.g., EC2) instances shall use hardened VMIs. If a custom VMI is absolutely necessary, the Program Manager shall coordinate the business justification with NGA's Risk Management Team prior to installation.*

(U) **Guidance:** *SSH Access Keys and credentials will not be stored in publically accessible directories.*

(U) **Guidance:** *Programs should continuously scan for and remediate critical and high vulnerabilities of the VMI selected for use. Note, in some cases the baseline VMI published for enterprise use may require STIG configurations conducted by the ASP.*

(U) Developers and administrators should at a minimum adhere to security best practices for EC2, as follows:

2.3.1 (U) Security Monitoring and Auditing:

- Employ granular access to different administrative functions in order to maintain separation of duties.
- Configure instances to send important local security log files to the organization's centralized log management system for analysis.
- Minimize the attack vector by separating application components across security groups to prevent horizontal attacks. Critical components that do not absolutely require public access are to be maintained in private subnets.
- Audit access and all changes to EC2 instances to verify server integrity to ensure only authorized changes are made. Identify all system and application logs as well as the software components that generate EC2 instance logs.
- Deploy host-based firewalls to restrict inbound and outbound traffic.

2.3.2 (U) Access Control:

- APIs should be encrypted with TLS in order to maintain confidentiality and access to individual APIs is to be restricted to maintain least privilege.

- Separate administrative accounts are to be created and multifactor authentication required for access to these accounts.
- Define the minimum set of privileges each server needs in order to perform its function.
- Require multi-factor authentication for access to the management plane. All such access is to be logged and audited, and privileges are to be revoked when there is no longer a business need for administrative access.

2.3.3 (U) Data Security:

- OS and applications on instances are to be patched regularly in order to keep them updated and secure.
- Employ encryption protocols such TLS or IPsec on all traffic between EC2 instances, AWS API endpoints, and all other sensitive endpoints in order to maintain confidentiality.
- Standardize naming conventions of instances to reduce manual errors.
- Utilize independent EBS volumes for the OS and data ensuring that the volume holding the data persists after instance termination.
- When not in use, instances should be stopped. Instance data should not be held in temporary storage in order to prevent data loss when instances start and stop. Termination protection is to be used in order to prevent accidental termination of instances.
- Take regular EBS snapshots. Maintain backups of the snapshots and periodically verify the integrity of the data within the backup copies.
- Regularly test the process of recovering instances and EBS volumes to ensure safe recovery in the event of a system failure.

2.3.4 (U) Configuration Management:

- Maintain a baseline configuration and track each server as a configuration item (CI).
- Assess each server against the current baseline to identify any deviations.
- Maintain an AMI catalog that contains security configuration baselines to ensure all instances are launched with standardized security controls.

2.3.5 (U) EC2 Key-Pairs:

- Regularly rotate SSH key pairs for EC2 instances.
Use pass phrases to protect keys from unauthorized access as they provide greater protection than standard passwords.
- Use non-standard ports to reduce the possibility of being noticed by port scanning technologies. However, all ports, protocols, and services must be authorized by NGA Risk Management and DISA.
- Private keys must not be stored in publicly accessible directories. Restrict key access to only those users who are authorized to use those keys.

- Properly dispose of keys. Completely remove all key pairs that are no longer attached to an EC2 instance.

2.4 (U) AWS Auto Scaling

(U) **Guidance:** Activities should configure Auto Scaling to use multiple AZs. If one AZ becomes unavailable, Auto Scaling can launch instances in another one to compensate.

(U) AWS Auto-Scaling is a service which allows consumers to launch and/or terminate EC2 instances to appropriately handle the demand for the application. By specifying auto scaling groups users can define a policy which establishes a minimum, maximum, and desired number of instances given the necessary performance the application must maintain. Automatic scaling of instances within a cloud environment contributes to enterprise cost savings. It also reduces the impact of incidental denial of service (DOS); and, should the demand of an application rise, the application shall remain accessible.

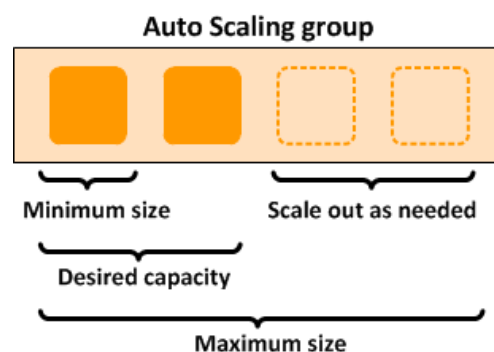


Figure 1: (U) Auto Scaling Policy

2.5 (U) AWS Trusted Advisor

(U) **Guidance:** Programs should utilize CSP security validation tools (e.g., AWS Trusted Advisor) to scan for security vulnerabilities (separate from the ACAS scans) before ATO and continuously after ATO is obtained.

(U) **Guidance:** Programs should refer and adhere to the guidelines specified within the security validation tool (e.g., AWS Trusted Advisor) SOP.

(U) The AWS Trusted Advisor service provides a mechanism to monitor and validate that the environment is optimized for cost, performance, fault tolerance, and security. The service scans the cloud resource's configuration against pre-defined best practices. For example, Trusted Advisor will verify that a resource's Security Groups are restricted to ports rather than open to all external access points. The service's continuous monitoring and reporting dashboard provides valuable security recommendations and alerts when potentially insecure cloud configurations have been employed.

2.6 (U) Securing Cloud Data

(U) [Intelligence Community Directive \(ICD\) 501](#) authorizes the DNI to produce and mandate metadata standards for the IC to adhere to in the cloud. The DNI has published guidelines and specifications for the use of Enterprise Data Headers (EDH) and Trusted Data Formats (TDF) to condition and standardize mission data for use. Specific guidance and format information on EDH and TDF can be found in Annex G: Cloud Data Guidance.

(U) The Chief Data Officer (CDO) seeks to apply the enterprise services needed to discover, access and transform NGA data for use by any activity. Obviously that cannot be done with classified and controlled information. However, automated access via Policy Enforcement Points (PEPs) is being applied, so that when user credentials meet the metadata attributes, the authorized user can access the data. Anyone with the rights and need to know would be granted access to the data.

(U) Data sets are tagged for ingestion into the cloud to identify what the data is, the classification of the data, under what authorities the data was received and what policies apply to the use of this data (i.e., need to know, restrictions on use) to support Attribute Based Access Control (ABAC). Additional tags may also be applied to support a broad range of automated enterprise operations, such as discovery, retrieval, retention, and records management.

(U) Data security will be handled at the object level, with the mandate to leverage EDH and TDF, access, discovery and retrieval will be handled at the metadata level.

(U) Additional guidance can be found in the NGA Cloud Data Guidance Annex G.

2.7 (U) Cloud Security Services

(U) **Guidance:** *Activities in the cloud shall integrate with the IC ITE Common Service Providers (CSPs) enterprise security services to eliminate duplication of security services.*

(U) Deploying consistent security services throughout the enterprise and across all domains is the IC ITE goal. Instances will exist where the domain architectures and/or security risks may require deviation. Employing and managing a single baseline of security services enhances the ability to effectively monitor security compliance and effect enhanced cybersecurity.

(U) NGA's approach to securing the cloud is to deploy security services that are consistent throughout the enterprise and across all security domains. The goal is to employ and manage a single baseline of security services that provide the necessary levels of security.

(U) The [Enterprise Service Catalog](#), located in NGA's ATLAS identifies the available cloud security service offerings.

2.8 (U) Data Encryption

2.8.1 (U) Encrypting Data in Transit

(U) **Guidance:** *Data traversing across and between cloud environments will be encrypted.*

(U) **Guidance:** *Data exiting the cloud environment will be encrypted.*

2.8.2 (U) Encrypting Data at Rest and Key Management

(U) **Guidance:** *Data residing in the cloud will be encrypted.*

(U) **Guidance:** *Regardless of domain, programs managing Personally Identifiable Information (PII), Health Insurance Portability and Accountability Act (HIPAA), and Special Access Program (SAP) data will use a FIPS 140-2 Level 3 compliant key management solution.*

(U) **Guidance:** *PII, HIPAA, and SAP keys will be stored outside of the cloud, regardless of the security domain which they reside.*

(U) **Guidance:** *Impact Level 2 data and above (excluding PII, HIPAA, and SAP data sets) should leverage CSP key encryption services (e.g., AWS KMS) to encrypt cloud stored and compute data (e.g., EBS volumes, databases, S3 buckets, Snowballs).*

(U) **Guidance:** *Programs shall obtain privileges as a Key Admin role from the Cloud Operations team prior to creating keys and associated policies.*

(U) **Guidance:** *CSP maintained data transport devices (e.g., AWS Snowballs) will undergo double encryption to protect Unclassified data during physical transport of the device.*

(U) One of the main reasons for encrypting data is policy compliance. Data encryption provides for the enforcement of Confidentiality and Integrity for the various types of data that policy requires additional protection, such as PII, HIPPA, and Controlled Unclassified Information (CUI).

(U) Data at rest refers to data that is being stored. Data at rest is frequently defined as data that is not in use or is not traveling to system endpoints, such as S3 buckets, other systems, or any network file storage.

(U) The need for the encryption of data-at-rest will be based on the data protection requirements. There are multiple factors that dictate the solution to be employed, which include data protection requirements, the technology, and the domain the data resides.

(U) Encryption key management is administering the full lifecycle of cryptographic keys and protecting them from loss or misuse. The lifecycle includes: generating, using storing, archiving, and deleting of keys. Protection of the encryption keys includes limiting access to the keys physically, logically, and through user/role access.

(U) The [Data Encryption White Paper](#) provides guidance for the utilization of the two approved solutions for use by NGA programs. These solutions are AWS Key Management Service (KMS) and Vormetric within the C2S environment. This document describes processes and guidelines for executing various key management functions and defines roles and responsibilities for KMS integrated services that are supported within the C2S environment.

2.9 (U) Identity and Access Management

(U) **Guidance:** *Activities migrating to CSP services (e.g., C2S) shall integrate with GEOAxIS until such time that IC ITE's IAA services can fully accommodate NGA mission application requirements.*

(U) GEOAxIS is NGA's Enterprise IdAM solution on all three security domains (TS, S, U). Activities will continue to leverage GEOAxIS services until IAA is completed. GEOAxIS provides the capability to control privileged access to the Cloud Access Point (CAP) for NGA's Unclassified Cloud and Secret Cloud. GEOAxIS' IdAM services (e.g., AuthN, AuthZ) are in place to broker requests to protected resources.

(U) The GEOAxIS Consumer Integration team facilitates program integrations. Programs will apply the [PM's Guide to Cloud Migration](#) and contact NGA's security POCs for integrating GEOAxIS services. For additional information on GEOAxIS services see:

- [GEOAxIS \(C2S\)](#)
- [GEOAxIS \(SC2S\)](#)
- [GEOAxIS \(Unclassified\)](#)

(U) Authentication (AUTHN)

(U) **Guidance:** *Activities will enforce PKI authentication for user and non-person entities accessing their applications and services.*

(U) In almost cases, except for publicly releasable material, activities must authenticate the user or the calling service, or both. Generally, for the web browser model, authentication can be offloaded

to either GEOAxis or the web server that a web app is operating in; the pattern redirects the user to an authentication mechanism and control is not returned until the user is verified to have authenticated.

(U) In other models, particularly for back end applications and services that don't have a direct connection to the user, they must both authenticate the requesting service and accept an authentication assertion (i.e. token) that validates that the end user was authenticated.

(U) In addition to the GEOAxis and web server features for authenticating the user, activities that communicate with other activities must mutually authenticate using two-way TLS. This establishes an encrypted channel and also satisfies the PKI requirement. Activities should rely on GEOAxis to provide all of the user authentication processing for the variety of credential types, form factors, and degrees of authentication assurance. In cases where PKI is not a possible authentication method, the Activity must consult Risk Management and GEOAxis to document use cases and determine a secure mechanism that provides an acceptable degree of assurance for the entity being authenticated.

(U) Activities deployed onto Pivotal Cloud Foundry may also integrate with the Single Sign On (SSO) Service Tile which provides GEOAxis AUTHN API services for application users.

(U) A PKI-based authentication reduces the risk imposed by the use of username/password, which is the weakest form of authentication. Non-PKI scenarios include foreign partners without a PKI credentialing system; and, State, Local and Tribal users who have the same impediments; and mobile users who can't use a CAC due of hardware limitations. These circumstances should be coordinated with Risk Management and GEOAxis to determine the most appropriate means for authentication.

(U) Authorization (AUTHZ)

(U) **Guidance:** *Activities should not attempt to construct their own authorization logic; leverage GEOAxis or AccessIT! which immediately applies the authorization logic as denoted by the GUI-defined policy.*

(U) Activities should call GEOAxis with a request for an authorization decision, passing the identity of the user (or calling activity), the action requested, and the resource (or resource metadata) being requested. GEOAxis or AccessIT! acts as the Policy Decision Point (PDP), retrieving the applicable policies, computing whether access is allowed, and returning a Permit or a Deny. The activity then acts as the Policy Enforcement Point (PEP), either allowing access or not.

(U) In some circumstances, the activity can request the user's attributes and determine for itself whether the user deserves access, acting as both a PDP and a PEP. In this case, the IdAM provider returns attributes to the activity that apply to the user (i.e., citizenship and clearance). The activity then constructs the logic to compare the clearance against the classification of the data and checking dissemination/releaseability against the REL markings.

(U) The specific approach to authorization varies pending the activity's software architectural model. Web applications that build the contents of a page piece-by-piece and for which each piece's restrictions can vary should call the authorization (AuthZ) endpoint. Services that expose only endpoints to other activities should also make authorization calls to GEOAxis. Activities using data from the OpenDataStore should first try to use the S3 PEP, which handles all authorization.

And as a last example, “Apps”, in the parlance of the API Gateway product Apigee, should rely on Apigee and the APIs (services) that it calls.

(U) Not leveraging these services requires justification to the Security Control Assessors and Risk Management. If these services potentially impact an activity’s performance, engage with GEOAxis and the OpenDataStore team.

(U) Often authorization can be done at the data level and the activity can inherit the key NIST 800-53 controls. In general, activities that actually manage the data are responsible for ensuring that the end user and the activity calling it are both eligible for the data being provided. One catch to this is that the application protecting the data may not understand its use; a user wanting to modify data may be able to read it but not change it; this distinction may be in the activity’s purview to authorize, but still by relying on GEOAxis to the extent possible. Note that it is possible for a user to not receive some data, due to an intermediate application or service is not accredited for that data.

(U) Note, activities should be building for risk-based approaches. This concept adjusts access via the level of risk, including systemic risk (e.g., crisis scenario), a vulnerable environment, and the user’s credential strength. These variables might alter what actions are allowed, or whether data is obfuscated or volume-constrained. Each activity should be considering the question of how would they change what a user can see or do given the risk level.

2.10 (U) Bastion Host

(U) **Guidance:** *System Administrators and other privileged users shall login using the Bastion Host for conducting elevated privileged functions.*

(U) The Bastion Host Remote Desktop Gateway Service provides secure access to privileged users who shall serve as system administrators. Identifiers and verification credentials provided to the Bastion Host are validated with the Active Directory service prior to granting access to an authorized privileged system admin account. Authorized privilege users shall use their general user account when performing non-privileged functions.

(U) Refer to the [IaaS Bastion Host Design Whitepaper](#) for details on the C2S Bastion Host implementation and use. Note that the Unclassified cloud’s Bastion Hosts will be maintained within the EntServicesOps_VPC instead of the activity’s public subnet.

2.11 (U//FOUO) Enterprise Cross Domain Services

(U//FOUO) **Guidance:** *Programs needing to leverage cross domain capabilities or connect to a cross domain should first receive authorization from NGA’s Cross Domain Support Office.*

(U//FOUO) NGA’s Enterprise Cross Domain Service (ECDS) is an enterprise-wide service satisfying NGA’s cross domain requirements. It provides capabilities to transfer file, socket and streaming data in all directions between multiple network environments. ECDS is a system-of-systems architecture, leveraging best-of-breed cross domain solutions, data filtering engines, and systems monitoring and management technologies to provide high assurance, low latency transfers of data.

(U//FOUO) ECDS is not currently deployed within the cloud however it’s services are still offered to activities residing within the cloud on all three domains. Detailed information on ECDS services

can be obtained at the [Security Engineering - Enterprise Cross Domain Home Page](#) or contact the NGA ECDS PMO.

2.12 (U) Enterprise Audit

*(U) **Guidance:** Activities shall comply with ICS 500-27.*

*(U) **Guidance:** Activities will serve as the responsible entity for the collection and forwarding of the necessary application logs.*

(U//FOUO) The [ICS 500-27, Collection and Sharing of Audit Data](#), mandates that IC elements audit information resources within IC element environments. NGA has implemented an enterprise audit solution that captures and stores audit events per ICS 500-27, Appendix B - *Set of Auditable Events*. The NGA enterprise AMIs are to be used for easy capture of OS logs.

(U) Activities in cloud environments are required to audit and log application activities to ensure:

- Application specific events are captured.
- S3 buckets are configured to the ICS 500-27, Appendix B requirements.
- All security related CloudTrail logs and alerts are forwarded to the Enterprise Audit repository for aggregation and correlation.

(U) Participating in onboarding events immediately following the program's Categorization and Selection TEM will ensure audit requirements and the [Enterprise Audit Onboarding Process](#) are addressed.

2.13 (U) Infrastructure Security

2.13.1 (U) Chef

*(U) **Guidance:** Activities shall use an automated enterprise configuration management tool for program development and operations.*

*(U) **Guidance:** When secure system configurations (e.g., Chef recipes) are modified they should be tested in a development/staging environment to validate functionality and availability of the changed environment.*

*(U) **Guidance:** Analytics should be implemented in support of the enterprise's operational risk assessment to quickly identify instances which are not within compliance.*

(U) Security is baked into the cloud architecture by leveraging automated enterprise configuration management tools such as Chef and Puppet to create recipes and hardening scripts to assure an approved and consistent security baseline is deployed with AMIs. The added benefit to this approach is verifiable compliance and an offering of quicker roads to authorization of applications by:

- Leveraging Infrastructure as Code for security automation
- Validating security relevant changes to code and environments
- Leveraging Chef recipes for consistent image deployments

(U) Configuration Management tools, such as Chef and Puppet, enable the creation of baseline templates that define the system security configuration. After a base template is established, privileged update and maintain those templates stored in the GitHub repository. By establishing a master template, security engineers and auditors understand exactly what is deployed onto the network. Secure configuration management can apply to any situation which has a defined repeatable security pattern across multiple instances, to include infrastructure as code, AMI hardening, or custom applications.

(U) Automating configuration management reduces the overall risk (as a result of human manual configuration errors), enforces and validates server policy compliance, simplifies patching across the distributed enterprise, enables rapid roll-backs, and reduces the time to deploy authorized environments. Figure 2 defines the high level process which development teams practice “baking-in” security.

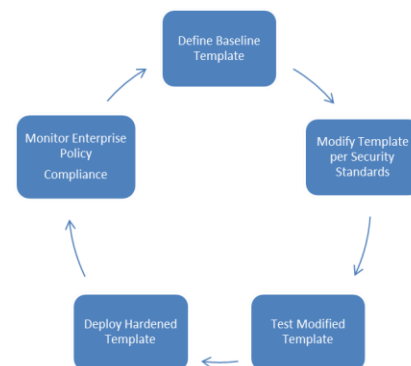


Figure 2: (U) Security Templating Process

(U) Chef allows application development teams to define Ruby-scripted ‘cookbook recipes.’ These recipes are the templates which developers leverage to streamline the installation, configuration, testing, and deployment of infrastructure and applications. When deploying Chef, refer to the [audit guidelines](#) to identify and remediate security patches to Chef’s software baseline.

(U) It is recommended as best practice for the Chef Server to enforce write privileges to a limited set of approved users to reduce exposure to malicious or incidental modifications. The Chef Server leverages the enterprise auditing tools (i.e. CloudTrail and HP ArcSight) to log all access and modifications to recipes which contributes to enterprise security. It establishes a rapid incident response process for immediate rollbacks and reduces the impact from insider threats.

(U) Once a Chef recipe is authorized and pushed to production, Chef clients will continuously call the Chef Server to identify and compare their current state with the desired state. If the clients do not meet the defined policy, they will automatically download and update their configuration with the new scripts.

2.13.2 (U) Puppet

(U) Puppet provides a node manager GUI which allows system administrators to create rules to update system attributes for a group of like-systems. For example, the node manager would enable a user to generate a single update for BIOS information which will propagate to all nodes. This capability reduces time and risk associated with manual configuration of individual instances. Like Chef, Puppet automates application deployment and orchestrates enterprise changes by enforcing the desired configuration state. Puppet’s reporting capability provides visibility into the security compliance posture, enabling enterprise tracking of all components and their corresponding modification history. When deploying Puppet refer to their [security disclosures](#) to identify and remediate security vulnerabilities from Puppet software.

(U) The Puppet agents frequently poll the Puppet Master Server to compare their current configuration state with the desired state found in the GIT repository. Should the agent have a different configuration, the server pushes an update to the appropriate agent. All server-to-client

updates are audited and reported to allow easy, efficient roll-backs, as needed. All updates and access the server are logged and captured in the enterprise audit solution. The master repository enforces RBAC to restrict permissions of project templates and modifications to agent attributes.

(U) Chef and Puppet allow consumers to inherit several NIST 800-53 configuration management controls; however, the implementation of internally developed or externally provided Ruby scripts allow developers to automate repeated patterns to account for other security controls (e.g., AMI hardening, audit log generation, and port configuration).

(U) Both tools simplify the management and enforcement of compliance policies. Their automation and propagation of hardened baselines reduce cost and risk from a manual configuration process; they effectively streamline the continuous integration/continuous delivery process allowing security to develop and accredit in an agile DevOps environment. Refer to the [Chef Design Whitepaper](#) for additional implementation details.

2.14 (U) Cloud Incident Response

(U) **Guidance:** *System and mission owners shall report any cyber related event.*

(U) **Guidance:** *Mission owners and NGA/SISCC shall adhere to the Cloud Sanitization and Spill Standard Operating Procedures upon system compromise and/or unauthorized disclosure of information.*

(U) A cyber event or a potential incident is defined in CJCSM 6510.01B or identified as a Category 1-9 classification event defined in the NGA CSOC SOP. The Computer Network Defense (CND) in a cloud environment is ever changing; and, NGA will take advantage of cyber technology to protect the data and the network. When handling an incident, responders will need to be familiar with specific services managed by the CSP such as:

- IAM - Managing identities (keys, security groups, policy, roles, and least privilege)
- EC2 - Instances, Instance types, Snapshots, AMIs, CloudFormation scripts
- S3 - Object Data Storage
- AWS Regions and Availability Zones
- CloudTrail & CloudWatch – Audit logs, API calls, instance monitoring
- Other services, such as EBS, VPC, Peering Connections, and CloudFormation

(U) The major difference in Incident Handling and Incident Response in cloud environments is the way that traditional ownership is defined and how a Computer Network Defense Service Provider (CNDSP) operates. Customers no longer have absolute control over how data is stored, routed, and the way it traverses the network. The CSP operates the ISP functions for the customer. Thus in the cloud, NGA has the responsibility for everything it deploys in the cloud that is not a part of the underlying infrastructure; which is essentially all application and the associated data.

(U) The shared responsibility model acts as a guide to NGA's CNDSP in reference to how cyber incidents are handled. As such, the CSP provides the tools to manage the configuration, logging, architecture and provide insight into traffic to and from any of the services that are being used. The CSP is responsible for responding to events within any of its services. However, any applications deployed within are the responsibility of the customer.

2.15 (U) Patch Management

(U//FOUO) **Guidance:** *Activities shall ensure instances are patched as agreed upon by NGA Risk Management.*

(U) Patch Management is key to ensuring that the operating system or back-end application is hardened to protect the environment from known vulnerabilities due to insecure system configurations. Activities will be able to leverage continuous ACAS Scans to verify that instances have been hardened to meet DISA STIG compliance.

(U) Two distinct patch management repositories are provided on each domain, one for Linux instances and one for Windows instances. The CSPs are not responsible for continuously patching the mission owner's instances, however they will maintain these repositories for enterprise consumption. Activities will be able to pull from these repositories to obtain the necessary patch updates. The CSP does not patch the mission owner's instances. However, they provide the repositories for mission owners to patch their own systems continuously. Consult the [Patch Management CONOP](#) for additional information. Also, refer to the Cloud Operations Team's SOPs for detailed information how to patch instances, the following SOPs may assist activities:

- UNC-SOP-0022: DIV Repo Provision
- UNC-SOP-0037: UNC WSUS Maintenance
- UNC-SOP-0039: UNC WSUS Install and Configuration
- AWS-SOP-0036: C2S WSUS Maintenance
- AWS-SOP-0044: C2S Patch Updating Windows with WSUS and Linux with YUM Patch Updates
- AWS-SOP-0063: C2S Linux Patching and Maintenance

2.16 (U) Host-Based Security Services

(U) **Guidance:** *Mission owners shall ensure successful HBSS integration with the ePO server.*

(U) HBSS Requirements are derived from USCYBERCOM. Waiver requests for HBSS requirements must be coordinated with the HBSS Ops Team and NGA Risk Management. HBSS integration with the ePO server can be coordinated with the HBSS@coe.ic.gov. Note that HBSS is built into the AMI provided for enterprise consumption. For additional information and guidance on host-based security refer to the [Host Defense Cloud Requirements Guide](#) and the USCYBERCOM TASK ORD 14-0305.

2.17 (U) Platform Security

(U) **Guidance:** *PaaS capabilities should be managed from dedicated Bastion Hosts residing within the cloud environment.*

(U) Bastion Hosts are hardened, purpose built workspaces dedicated for management within a domain. Access to the workload owner's application will be through an CSP account.

2.17.1 (U) Securing Containers

(U) **Guidance:** *PaaS containers shall first receive ATO authorization for enterprise employment prior to using commercial and custom container applications in production.*

(U) ATO authorization for containers includes the following CIO-T security coordination, supplementary to the standard ATO requirements:

- Foreign Owned Controlled & Influenced (FOCI): Process used to mitigate supply chain risks
- Software Assurance Program (SWAP): Process for NGA Programs to gain approval to utilize Open-Source, Freeware, Shareware, COTS, GOTS, and Foreign software
[Software Acquisition: \(SWAP Form, Software White List, SWAP Status Spreadsheet\)](#)
- Automated DevOps Security Process: Approval process for widgets and application; identifies vulnerabilities within software code using HP Fortify, SonarQube, OWASP Dependency Checker, OWASP ZAP, etc.

(U) Containers provide isolation between applications and between the application and the host operating system, which effectively reduces the attack surface to the container itself and to adjacent containers sharing the same infrastructure.

(U) The inherent nature of containers facilitates rapid and efficient patches to applications and reduces the amount of required patches to the underlying infrastructure as multiple containers can be deployed onto a single OS. This model mitigates many risks that result from individual application configuration management processes and contributes to a more effective security compliance strategy for the enterprise.

(U) With respect to the concept of inheritance, PaaS containerization applies the inherited security model. Once the organization secures the infrastructure layer, the container is responsible for securing the application data within the container. Securing the container boundary prevents modifications by unauthorized users, prevents data leakage between applications, simplifies audits and reduce impacts from insider threats.

(U) Administrators and Security Analyst:

- (U) **Guidance:** *Users accessing containers shall be authenticated and authorized access to each specific container.*
- (U) **Guidance:** *Applications and services deployed within containers shall run with non-root privileges to mitigate risk of privileged escalation.*

(U) Containers that require Root Privileges shall receive Risk Management authorization.

- (U) **Guidance:** *Container software should explicitly deny all network traffic between external connections and adjacent containers existing on the same host to mitigate the risk of data leakage to/from other containers.*
- (U) **Guidance:** *Activities shall only download signed official images created by trusted parties from the authorized container repositories.*
- (U) **Guidance:** *Activities should utilize control groups (Cgroups) to restrict access.*

(U) C-groups enforces application limits to a specific set of resources.

- (U) **Guidance:** *Activities should leverage configuration management tools to update the host's kernel attributes and propagate change to all nodes.*
- (U) **Guidance:** *Activities should only run task related containers on dedicated hosts.*

(U) For example, do not deploy a web application onto a host which hosts a database.

- (U) **Guidance:** *Activities should prohibit implementation of Set owner User ID (SUID) and Set owner Group ID (SGID) functions inside the container to avoid temporary privilege escalation.*
- (U) **Guidance:** *Activities should establish container orchestration configurations that ensure load-balancing and scaling to maximize availability.*
- (U) **Guidance:** *Activities should leverage scanning technologies to identify and remediate vulnerabilities resulting from insecure container configuration.*

(U) Refer to the [Securing Container Environments Standard Operating Procedures](#) for additional guidance on the security requirements for programs deploying containerized solutions. Applying container best practices will facilitate the accurate generation and monitoring of audit logs, identify the changes made by an individual, and mitigate insider threat risks. Contact the TSGOVAll@coe.ic.gov or TSCTRAll@coe.ic.gov to determine enterprise available vulnerability scanning technologies.

(U) Leverage the CIS Docker benchmark as technical reference how harden the configuration of the Docker container. Refer to the links below for most up-to-date benchmark: The above configuration guidance shall be leveraged to develop a Docker ‘gold image’ however development teams may need to apply additional configurations as identified in the CIS Docker Benchmark (<https://containeryard.nsa.ic.gov/resources.html>).

(U) Upon the implementation of an enterprise solution, the controls which consumers inherit from PaaS and containers (e.g., Docker) will be documented in the Information Assurance Requirements Catalog (IARC).

2.17.2 (U) Securing Pivotal Cloud Foundry

(U) Pivotal Cloud Foundry (PCF) is a PaaS container service that has built-in mechanisms to monitor an application’s performance. If an application was not meeting the defined performance criteria, PCF has the capability to reinitiate the instance to an optimum configuration. Operating in a PCF containerized environment provides the following inherent security features:

- Iteration of feedback of found vulnerabilities throughout the applications lifecycle.
- Restricts permissions to privileged users and developers that have unique account identifiers and appropriate role (separation of duties).
- Configures clients and users using BOSH manifest; limiting to privilege clients and users.
- Access can be restricted using the security groups.
- Restricts packets via security groups, leverages ACLs, restricts routing (i.e., only allows data needed to flow between systems)
- Restricts containers by denying all traffic except between other approved PCF instances and progressively allowing access to applications, as needed.
- Mitigates insider threat risk by removing ability to delete S3 buckets, VPCs, and backups.
- Integrates with auditing technologies such as CloudTrail to alert others when a change to an instance has occurred. Documents and logs termination and initiation of application instances.

(U) PCF reduces risk to the cloud environment by minimizing the network surface area, isolating data and applications found in containers, and establishing secure connections. PCF orchestrates resource allocation to all hosted applications which prevents potential denial of service due to resource starvation.

(U) PCF isolates applications which exist on the same VM and enables PCF operators to establish communication, as needed. PCF also restricts external traffic to known security groups which further mitigates threats of external spoofed IPs accessing the application containers.

(U) The controls which consumers inherit from PCF will be documented in the Information Assurance Requirements Catalog (IARC).

2.18 (U) Assessment & Authorization (A&A)

(U) **Guidance:** *All NGA Information Systems (IS) will undergo Assessment & Authorization (A&A) per NGA requirements.*

(U) The Assessment & Authorization (A&A) process, formerly named Certification & Accreditation (C&A), supports the decision by the Delegated Authorizing Official (DAO) to authorize the operation of NGA information systems (IS) at an acceptable level of risk. An IS will be assessed regardless of location, organization, and civilian, military, and contractor personnel involved in the acquisition, development, operation, and maintenance of the classified or unclassified system.

(U) The Federal Risk and Authorization Management Program (FEDRAMP), Intelligence Community Directive 503, and the DoD Cloud Computing Security Requirements Guide (SRG) form the basis for Assessment and Authorization approval. Reciprocity is a key aspect that NGA will embrace while seeking system assessment and authorization of legacy systems.

(U) The A&A process for activities transitioning into the cloud is outlined in Figure 3. The A&A process is initiated by the Information System Owner (ISO) upon notifying TSRiskManagementDAORTeam7@coe.ic.gov of the need for A&A services. The Risk Management DAOR Team Seven will respond to the request and coordinate with the Security Onboarding TEM (SOT).

2.19 (U) Risk Management Framework

(U) **Guidance:** *NGA Information Systems (IS) will apply the Risk Management Framework (RMF) process throughout the systems' lifecycle to manage security risks.*

(U) To manage security risk throughout the lifecycle, the NIST Risk Management Framework (RMF) will be followed for activities in the cloud, as outlined in Figure 5. NGA/CIO-T has defined a “Cloud Transition Security Process” to facilitate the secure migration and authorization of services and capabilities to the cloud. NGA’s IARC maps security controls to cloud capabilities as a guide for security control selection.

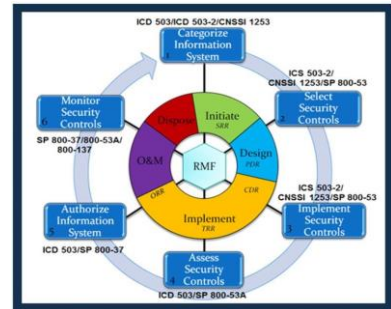


Figure 4: (U) RMF Process

2.19.1(U) Information Impact Level Determination

(U) **Guidance:** *Activities that intend to deploy at the unclassified level will determine their Information Impact Level (IIL), per NGA requirements.*

(U) An unclassified activity’s IIL, as defined in NIST SP 800-59 and DoD SRG shall be documented with the result in the [ATLAS](#). At the macro level, the process requires answering two main questions and is depicted in Figure 6.

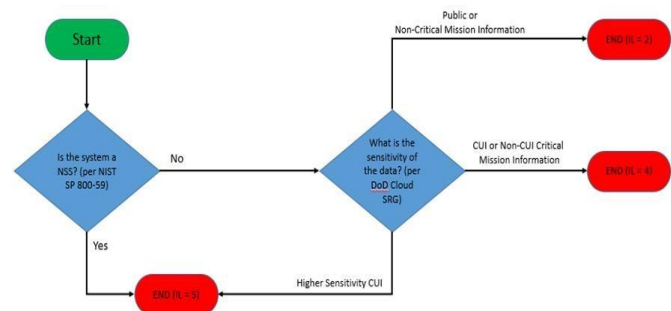


Figure 5: (U) Process to Determine Information Impact Level

(U) [NIST Special Publication 800-59, Guideline for Identifying an Information System as a National Security System](#),

requires that each unclassified system be evaluated to determine if it is a National Security System (NSS). An NSS is any information system that involves intelligence activities, cryptologic activities relating to national security, command and control of military forces, or equipment that is an integral part of a weapon or weapon system. NIST SP 800-59 provides a checklist that must be used to identify whether the system is an NSS.

(U) DoD Cloud Computing Security Requirements Guide (SRG) requires an NSS assessment in accordance with NIST SP 800-59 to select the appropriate IIL and controls needed to assess system security risk for any unclassified and secret systems. For the IIL security requirements, see Table 1.

(U) DoD SRG information impact level 2 is for Public or Non-critical mission information (non-NSS), level 4 is for Controlled Unclassified Information (CUI) or Non-CUI critical mission information (non-NSS) and level 5 is for higher sensitivity CUI NSS. Levels 4 & 5 must go through the DISA Connection Approval Process to ensure connections do not create a backdoor to NIPRNet. An information impact level 5 or higher designation is required for National Security Systems.

Table 1: (U) Information Impact Level Attributes

Key Security Requirements						
IMPACT LEVEL	INFORMATION SENSITIVITY	SECURITY CONTROLS	LOCATION	OFF-PREMISES CONNECTIVITY	SEPARATION	PERSONNEL REQUIREMENTS
2	PUBLIC or Non-critical Mission Information	FedRAMP v2 Moderate	US / US outlying areas or DoD on-premises or AO authorized locations	Internet	Virtual / Logical PUBLIC COMMUNITY	National Agency Check and Inquiries (NACI)
4	CUI OR Non-CUI Critical Mission Information Non-National Security Systems	Level 2 + CUI-Specific Tailored Set	US / US outlying areas or DoD on-premises or AO authorized locations	NIPRNet via CAP	Virtual / Logical PUBLIC COMMUNITY Strong Virtual Separation Between Tenant Systems & Information	ADP-1 Single Scope Background Investigation (SSBI) ADP-2 National Agency Check with Law and Credit (NACLC)
5	Higher Sensitivity CUI National Security Systems	Level 4 + NSS & CUI-Specific Tailored Set	US / US outlying areas or DoD on-premises	NIPRNet via CAP	Virtual / Logical FEDERAL GOV. COMMUNITY Dedicated Infrastructure	Non-Disclosure Agreement (NDA)
6	Classified Secret National Security Systems	Level 5 + Classified Overlay	US / US outlying areas or DoD on-premises CLEARED / CLASSIFIED FACILITIES	SIPRNet via CAP	Virtual / Logical FEDERAL GOV. COMMUNITY Dedicated Infrastructure	Favorable Adjudicated SSBI SECRET Clearance NDA

(U) Each program is expected to complete the NIST SP 800-59 checklist and document the NSS and information impact level on the System Security Plan (SSP) submitted to the Cloud Integration Team at the Cloud Architecture Technical Exchange Meetings (TEM). NSS designation and the DoD IILs are used to determine the appropriate controls required for RMF documentation and connection approval.

(U) All non-enterprise systems, programs, and software utilizing the unclassified AWS must capture their NSS and information impact level designation and complete the appropriate RMF controls/documentation prior to seeking connection approval.

2.20 (U) Shared Security Responsibility Model

(U) **Guidance:** *Activities shall apply shared security responsibility; whereby, they are responsible for securing their services and the CSP is responsible for securing the cloud infrastructure.*

(U) There are four perspectives by which security controls are implemented:

- **Cloud Service Provider** – controls as they apply to the cloud infrastructure (i.e., C2S, SC2S, and AWS-U). The consuming activity fully inherits these controls from the authorizations granted to the CSP by authorizing authorities.
- **Joint responsibility** – controls where a combination of the CSP and consuming entity or organization plays a role in control implementation.
- **Consumer responsibility** - controls for which the consuming activity or the account owning organization is fully responsible.
- **Common Service Provider** – controls that are met by an agency(s) enterprise services (e.g., AccessIT! or GEOAxis).

(U) The Shared Security Responsibility Model concept contributes to the overall inheritance control structure, minimizing the necessary controls needed for documentation and technical

implementation; thereby, reducing the cost and time for programs to accredit their cloud instances.

2.20.1 (U) Security Inheritance Model

(U) **Guidance:** *Activities shall apply the security inheritance model; whereby, they inherit the A&A approved security controls when used as an integral component of the service or system.*

(U) The shift to layered services (e.g., IaaS, PaaS) brings tremendous opportunities for security control inheritance to further reduce the program's need to document and implement select security controls. Should a program employ specific services or processes they can 'inherit' the control from an external service. These controls could be partially or fully inherited pending the implementation and use.

(U) The list below includes NGA Common Control Providers (CCP) and a brief description how each is inheritable. CCPs prefaced by "Cloud" solely applies to systems deployed within cloud environments, and CCPs prefaced by "Enterprise" or "NGA" apply to all NGA systems regardless of environment.

- **Cloud Baseline and CAP:** CCP that is inheritable by NGA Cloud systems in the UC & TC.
- **Cloud (UC)DevOps:** CCP that is inheritable by NGA UC Cloud systems being developed in DevOps
- **Cloud EC2:** CCP that is inheritable by NGA Cloud systems utilizing EC2 in UC & TC
- **Cloud S3:** CCP that is inheritable by NGA Cloud systems utilizing S3 buckets in UC & TC
- **Cloud Trail & Cloud Watch:** CCP that is inheritable by NGA Cloud systems utilizing Trail & Watch in UC & TC
- **Cloud VPC:** CCP that is inheritable by NGA Cloud systems in the UC & TC
- **Enterprise Active Directory:** CCP that is inheritable by NGA systems (Windows based) utilizing the enterprise active directory service. This service is provided by TII (Open IT Solutions Office). Contact #NGA O&M Active Directory Services Team to onboard. POC: omadst@coe.ic.gov
- **Enterprise Audit (ArcSight):** This can be selected as long as Enterprise Audit has been fully on-boarded. This service is provided by TOCC (Cyber Security Ops Division). Website for Onboarding.
- **Enterprise Corporate Services:** CCP that is inheritable by all NGA systems connected to the domain. CCP provides information handling/retention, rules of behavior and security training records. This service is provided by TQ (Corporate Services office)
- **Enterprise Cyber Engineering:** CCP that is inheritable by all systems on NGA networks. CCP manages IT architecture, engineering & integration and common standards. This service is provided by TAE (Enterprise Engineering Office)
- **Enterprise Cybersecurity office:** CCP that is inheritable by all NGA systems, regardless of connectivity. CCP provides Cyber Policy/A&A/CISO. This service is provided by [TS \(Cybersecurity Office\)](#).
- **Enterprise Cybersecurity Service Provider:** CCP that is inheritable by all NGA systems that are connected to an NGA domain. CCP manages the CSOC. This service is provided by TOCC (Cyber Security Ops Division)

- **Enterprise Endpoint Application Whitelisting (Carbon Black Protect) SBU/SECNet only:** CCP that is inheritable if program on-boards with Carbon Black Protect on SBU and SECNet only. This CCP prevents unauthorized programs to be installed/run. This service is provided by TOCC (Cyber Security Ops Division). Contact [#NGA Carbon Black](#) to onboard.
- **Enterprise Endpoint Investigation (Carbon Black Response):** CCP that is inheritable if program on-boards with Carbon Black Response. This service is provided by TOCC (Cyber Security Ops Division). Contact [#NGA Carbon Black](#) to onboard.
- **Enterprise Endpoint Security (HBSS):** This Enterprise Security Service can be selected as long as HBSS has been fully on-boarded. This service is provided by TOCC (Cyber Security Ops Division). Open a [Remedy ticket for "Modify Cyber Tool Services"](#) to onboard.
- **Enterprise GEOAxis:** CCP that is inheritable by NGA systems utilizing GEOAxis to Authenticate and Authorize in the domain. This service is provided by TII (Open IT Solutions Office). Refer to the [Onboarding GEOAxis](#) site.
- **Enterprise Identity Management (PKI):** This can be selected as long as Enterprise Identity Management has been fully on-boarded. This service is provided by TOCC (Cyber Security Ops Division). Open a [Remedy ticket for "PKI Service Request"](#) to onboard.
- **Enterprise Patch Management (SCCM):** CCP that is inheritable by all NGA systems that accept automated patching.
- **Enterprise Service Performance:** CCP that is inheritable by all NGA systems that are connected to an NGA domain. This service is provided by TOP (Service Performance Office)
- **Enterprise Service Performance:** CCP that is inheritable by all NGA systems that are connected to an NGA domain. This service is provided by TOP (Service Performance Office)
- **Enterprise Software Asset Management:** CCP that is inheritable by all NGA Systems. This CCP provides enterprise software licensing tracking. This service is provided by TIS. Refer to the [Software Asset](#)
- **Enterprise Software Assurance & Validation (SWAP):** CCP that is inheritable by all NGA systems. This CCP provides validation of all requested software. This service is provided by TAC. SWAP Website.
- **Enterprise System Monitoring:** CCP that is inheritable by all systems on NGA networks as long as on-boarding with Enterprise monitoring takes place (i.e. Enterprise Management Tools (BMC ProactiveNet Performance Manager (BPPM), HP Network Automation (HPNA)). This service is provided by TOCM (Enterprise Management & IC Services Div. Open a Remedy ticket for "Request Monitoring" to onboard.
- **Enterprise Vulnerability Scanning (ACAS):** CCP that is inheritable by all NGA systems on the Domains and can be scanned by ACAS (with credentialed Access). This service is provided by TOCC (Cybersecurity Operation Division. Refer to the [ACAS Website](#).
- **NGA Asset Management:** CCP that is inheritable by all NGA owned systems. CCP provides physical asset management oversight. This service provided by TOPA (IT Asset and Audit Management). Asset Management Website.
- **NGA Corporate Communications:** CCP that is inheritable by all NGA systems. This CCP provides oversight to publicly releasable information. This service is provided by NGA

Office of Corporate Communications. Refer to the [OCC Website](#) for Public Release Procedures.

- **NGA Counter Intelligence:** CCP that is inheritable by all NGA systems. This CCP provides TEMPEST, Supply chain protection. This service is provided by NGA Office of Counterintelligence (SIC).
- **NGA Cross Domain Services:** CCP that is inherited by NGA Cross Domain Systems. This Service is provided by NGA Open IT Solutions (TII).
- **NGA Human Development:** CCP is inheritable by all NGA systems residing at NGA facilities. This CCP provides oversight in positions and job screening. This service is provided by Human Development (HD).
- **NGA Insider Threat:** CCP that is inheritable by all NGA systems. This CCP provides info system account monitoring and insider threat security incidents. This service is provided by Insider Threat Office (SII).
- **NGA Installation Operations:** CCP that is inheritable by all non-cloud NGA systems located at NGA facilities. This CCP provides environmental, facility and capacity planning oversight. This service is provided by Installation Operations Office (SIO).
- **NGA Office of Security:** CCP that is inheritable by all NGA systems located at NGA facilities. This CCP provides oversight for Cyber investigations, industrial and physical security and personnel security.
- **NGA Open IT Solutions:** CCP that is inheritable by all NGA systems residing on the domains. This CCP provides Transport, Enterprise backup, telephony, COMSEC and personal IT device oversight. This service is provided by Open IT Solutions Office (TII).
- **NGA Operations Center:** CCP that is inheritable by NGA systems. This CCP provides oversight on contingency planning. This service is provided by NGA Operations Center (DON).
- **NGA Privacy Management:** CCP that is inheritable by all NGA systems. This CCP provides oversight on PII/PHI guidance and procedures. This service is provided by Strategic Planning Group (TC).
- **NGA Protective Services:** CCP that is inheritable by all non-cloud NGA systems located at NGA facilities. Provides oversight to physical intrusion alarms and physical/environmental policy. This service is provided by Office of Protective Services (SIP).
- **NGA Strategic Planning:** CCP that is inheritable by all NGA systems. This CCP provides oversight to Enterprise Architecture and portfolio/financial management. This service is provided by Strategic Planning Group
- **NGA Support Agreements:** CCP that is inherited by all NGA information systems. This CCP provides oversight and retention of support agreements between NGA and other partnering agencies/companies. This service is provided by the [Office of Director of Chief of Staff, Support Agreements \(DCOA\)](#).

2.21 (U) ATO Self-Assessment

(U) **Guidance:** *Programs should complete a self-assessment to validate the readiness of documentation and technical implementation for ATO A&A.*

(U) The ATO readiness self-assessment identifies key items required for the authorization package and allows a program to gauge readiness for the ATO's A&A activities. The self-assessment shall focus on:

- Enterprise Security Service integration
- Body of Evidence (BOE) completion
- Accurate and secure implementation of controls
- Remediation of known vulnerabilities

(U) Contact TSTAssessmentGuidance@coe.ic.gov should the program have questions about specific controls, requirements, or the SCA test itself.

2.21.1 (U) Body of Evidence

(U) Table 2 details the Body of Evidence (BOE) required to achieve each level of authorization.

Table 2: (U) Body of Evidence (A&A) Requirements

UNCLASSIFIED			
CAST	ATP	IATT	ATO
• Categorization and Selection Worksheet completed in XACTA * • CONOPS - draft • Boundary Diagram - draft • Ports Protocols and Services (PPS) - draft • ISO Responsibility Letter Signed* • Program Schedule • Privacy Threshold Analysis (PTA) Form*	• SSP (draft) • Security control traceability matrix (SCTM) • Security assessment plan (SAP)	• SSP (complete) • SCTM • Security test plan (STP) • Software Assurance Process (SWAP) • PPS	• SSP (including answers to the SCTM) • STP • Configuration management plan (CMP) • Audit log reporting

*Document included in post-SOT email from Team 7

(U) Note, should an activity have a REvAMP Level 0-2, the post-CAST requirements may potentially be further reduced.

2.22 (U) Risk Evaluation Acceleration Management Process (REvAMP)

(U) **Guidance:** *Programs shall apply REvAMP to facilitate an efficient and timely A&A process.*

(U) NGA's REvAMP underlying goal is to reduce the time, cost, and resources necessary for instances to obtain ATO should those instances meet specific criteria based on their current risk level. This framework to efficiently conduct A&A for all systems with a common methodology agnostic to the development environment or security domain. The approach allows decision makers to consider the operational and economic costs of protective measures weighed against requirements for mission accomplishment" (Ref.: [ICD 503](#), D.1.b).

(U) This approach employs a risk evaluation model which is divided into six (6) levels based upon access, data sensitivity, connectivity, threat landscape, and adoption of enterprise services. System Owners determine the appropriate A&A level as their mission dictates, based upon the matching level constraints and criteria. It was noted, the levels can be partitioned into two basic groups: 1) levels 0, 1, and 2 applying A&A certified services' inheritance for their requisite A&A security controls, and 2) levels 3, 4 and 5 require full BOE documentation.

(U) By implementing REvAMP, NGA shall:

- Reduce the BoE and testing requirements for lower risk systems
- Shorten A&A processing time
- Free resources to concentrate on higher risk assets
- Facilitate rapid authorization of Enterprise and cloud information systems
- Establish reciprocity between NGA security domains
- Drive program integration with NGA's automated DevSecOps pipeline

Level 0	• Stand-alone system
Level 1	• Internal TS//SI/TK cloud capability
Level 2	• Internet-accessible cloud capability allowing username and password
Level 3	• System hosting PII data or requiring reciprocity
Level 4	• INT-B Compartmented system
Level 5	• Cross domain system

Figure 5: (U) REvAMP Risk Evaluation Levels

(U) To qualify for reduced controls and BOE requirements, a program must meet specific criteria which contribute to risk-reduction. These requirements for REvAMP level 0, 1, and 2 are defined in Table 3.

Table 3: (U) REvAMP (Levels 0-2) Qualification Criteria

	Unclassified Cloud	Top Secret Cloud	Non-Cloud
0	• NGA internal access only • IL-2/UNCLASSIFIED data only • Full ESS integration • Must have DAR-Encryption • 29 controls assessed	• NGA internal access only • Up to Collateral data • Full ESS integration • Must have DAR-Encryption • Must use PKI • 27 controls assessed	• Logically or physically standalone • No restrictions on information types, data types or overlays • 46 applicable controls; DAOR spot check of random selection – no SCA assessment
1	• Authenticated (e.g., CAC/PIV) access OR webpage using PCF (open to internet) • 47 controls assessed	• Up to TS//SI/TK data • 39 controls assessed	• NGA internal access only • Full ESS integration • IL-2/UNCLASSIFIED data only • Up to Collateral data • 54 controls assessed
2	• IL-4/CUI • Username/password access from Internet • 49 controls assessed	• Community Access • 43 controls assessed	• NGA internal access only • IL-4/CUI • Up to TS//SI/TK data • 54 controls assessed + overlays

(U) Conditionally, Level 0 & 1 categorized services are able to achieve a six (6) month Limited ATO with self-scans and documentation review only; and, a full assessment of identified controls shall lead to a 3 year ATO. In addition, REvAMP establishes reciprocity between domains and defines it a "level-minus-one" (e.g., L-1 TC Cloud ATO = automatic L-0 ATO in UC upon verification)

operating constraint. Programs who fall under the upper Level 3-6 (i.e., enterprise/cross-domain) will obtain their full list of requirements post-CAST. More information on REvAMP can be found in the Categorization or Implementation sections on the [NGA/TSR Reference Library](#).

2.23 (U) DevOps Security

(U) **Guidance:** *Programs shall apply DevOps Security processes to facilitate an efficient and timely A&A process and production operations.*

(U) Security plays a vital role in ensuring the development and deployment of capabilities. In order to support the changing needs of development, the way in which we think about and do security must change as well. The NGA DevOps pipeline integrates security and applies automated testing, infrastructure as code, and configuration management for maintaining security in an agile enterprise.

(U) To achieve the goal of “baking-in” security, automation of security facilitates the developer’s ability to deploy applications to operations.

(U) Continuous development offers developers tools and libraries needed to design and build secure applications. Continuous testing introduces security testing into the automated application testing process, ensuring the applications provide a certain level of security.

(U) Applications in operations must execute cyber-security in order to provide the needed protections, including user feedback and proactive actions (i.e., vulnerability patches) to resolve security issues.

(U) The A&A of applications in the DevOps pipeline requires a layered security approach. The use of containers facilitates a layered approach to security. The combination of the many security controls offered from the infrastructure, container and application services form the foundation of the layered security approach (i.e., hardened shells) to the application. Refer to [DevOps 101](#) documentation to assist with onboarding, integrating, and using the DevOps tools and environments.

(U) DevOps tools can be accessed using PKI or Disadvantage User Accounts. Unclassified developers who do not have a Common Access Card (CAC), at a minimum, will need to undergo a National Agency Check with Law and Credit review. Refer to the UC Account Creation PM Guide on associated use cases and necessary requirements to authorize non-CAC developer user access.

(U) A notification is sent to a sponsoring Government Point of Contact (GPOC) for review and approval. If privileged user access is required the following form must accompany the access request: [Privileged User Security Acknowledgement Form](#).

(U) DevOps is embodied in a CI/CD pipeline and its toolchain. Figure 6 outlines the steps in the pipeline through which software is built, tested and deployed. The “toolchain” refers to the automation tools that help developers and IT operators to effectively and repeatedly deliver software capabilities from development to operations.

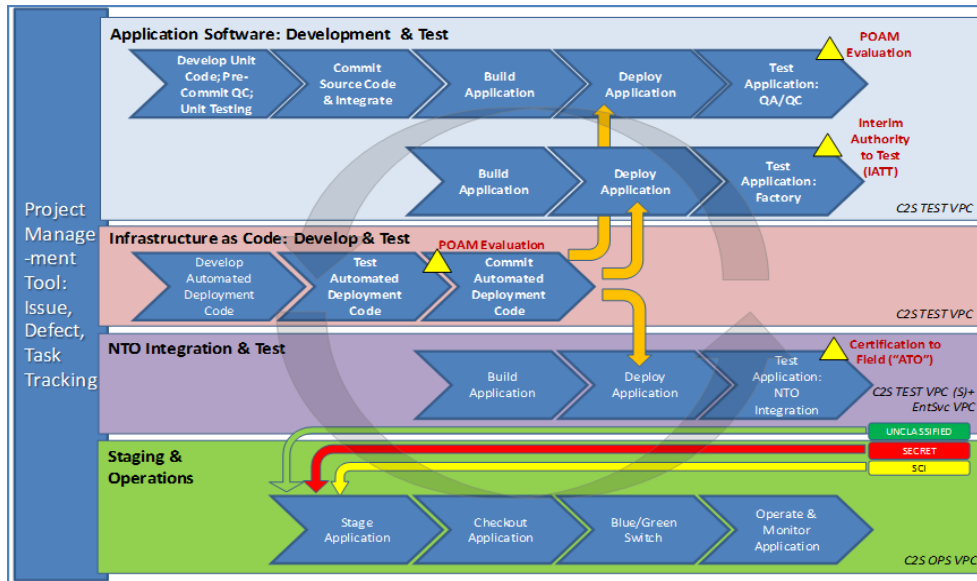


Figure 6: (U) DevOps Pipeline

2.23.1 (U) Static Application Security Testing (SAST)

(U) SAST is a 'white-box' technology that analyzes application's source code, binaries, libraries, and third party code for vulnerabilities while the application is in a non-running state. This analysis occurs continuously within the development VPC each time the code is committed to the build repository.

(U) HP Fortify and SonarQube SAST tools together offer a wide variety of programming languages allowing for diversity in development.

(U) Prior to promoting code to the Dev/Test VPC all vulnerabilities flagged as Critical or High must be remediated. In the event vulnerabilities cannot be remediated, the program manager must provide: 1) strong mission justification/impact for correction, and 2) a Plan of Action & Milestone to investigate/adjudicate in future development.

(U) Please refer to the DevOps Developer Guidance for detailed information on integration to establish automation of the SAST products.

2.23.2 (U) Dynamic Application Security Testing (DAST)

(U) DAST is a 'black-box' technology that analyzes and identifies security vulnerabilities within web applications, while in a running state. DAST technologies do not have access to the source code.

(U) At a minimum, automated DAST scans are done in the Test VPC to identify, remediate, and assess applications prior to deploying to a staging and operational environment. Best practices recommend deploying DAST tools in Test VPCs, to mitigate vulnerabilities early, and Production VPC, to fulfill continuous monitoring requirements.

(U) HP WebInspect is the DAST technology integrated into DevOps lifecycle. HP WebInspect scans the entire application for vulnerabilities such as SQL injection, cross-site scripting, brute force dictionary attacks, parameter fuzzing, etc.

(U) Remediation of all vulnerabilities flagged as Critical or High is required prior to promoting code to operations. In the event that vulnerabilities cannot be remediated, the program manager must provide: 1) strong mission justification/impact for correction, and 2) a Plan of Action & Milestone to investigate/adjudicate in future development.

(U) Please refer to the DevOps Developer Guidance for Jenkins integration to establish automation of HP WebInspect.

2.23.3 (U) Interactive Application Security Testing (IAST)

(U) IAST is a 'gray-box' technology that analyzes and identifies security vulnerabilities within web applications, while in a running state however unlike DAST technologies, IAST tools do have access to the source code. Access to this source code enables development teams to identify the line of code that may be the root cause of exploitations. This allows for a more rapid and efficient mitigation of vulnerabilities throughout the testing DevOps phase.

(U) IAST capabilities available in HP WebInspect contribute to the DevOps compliance assessments.

2.23.4 (U) DevOps Software Security Testing

(U) **Guidance:** *Programs should use the DevSecOps tools which scan applications for quality, static, dynamic, and dependencies security checks.*

(U) In the event that a specific scan cannot be conducted due to incompatibility with the application's language or configuration, coordinate with [NGA Risk Management](#) and the [GEOINT Services DevOps Support Team](#).

(U) **Guidance:** *Prior to deploying to a production environment, applications will meet the appropriate threshold for security scans.*

(U) Applications with Critical or High findings may not deploy into an operational environment without authorization from [NGA Risk Management](#).

(U) **Guidance:** *Vulnerabilities documented flagged as Critical or High shall be adjudicated, even when a false-positive has been flagged.*

(U) NGA/TST and NGA/TSR will verify flagged vulnerabilities are false-positives but will require details on why it is not a weakness; explaining the protections in place to prevent exploitation, as needed.

(U) **Guidance:** *ATO security testing shall not occur in environments external to NGA's accreditation (e.g., [devops.geointservices.io](#)).*

(U) Two fundamental DevOps tenets are automation and repeatability. Trust in DevOps-derived security is predicated on adherence to prescribed processes, tools, resources, and services. Authorization is based, in large part, on software security test results and remediation. These are the principles guiding development of NGA's DevOps software security testing methodology.

(U) NGA's Unclassified [Devops.gs.mil](#) environment shall serve as the environment which NGA TS shall assess and authorize unclassified applications.

(U) Figure 7 illustrates the basic functional components of a DevOps software security testing minimum viable product (MVP). They are, in workflow order:

- **Orchestration** - the triggering, workflow, and decision logic based on DevOps pipeline upstream actions (e.g., code commit) and downstream code/application test results.
- **Test suite** - tools that perform actual code/application testing and can include a variety of static, dynamic, package dependency, and code quality testing tools. Suitable tools can vary depending on application technology.
- **Vulnerability management** - the consolidation, correlation, and de-duplication of test results within a single platform/repository.
- **Remediation management** - supports the ability to automatically create and manage records, for developer consumption/action, in a software defect tracker tool based on security testing tool results.



Figure 7: (U) DevOps Software Security Testing Workflow

(U) All these components should, ideally, integrate and interoperate. Integration can be achieved in a variety of ways including command line interface, application programming interface (API), plugin, and in-built from the product vendor. Depending on the component, integration with other components may be difficult or not possible. This can, in turn, be a determining factor in choosing components. Components that don't play well with others may not be the best choice.

(U) It should be mentioned that automation has its limits even when tools that comprise the DevOps testing pipeline are fully interoperable. There will still be initial set-up and ongoing test suite tool tuning (e.g., to minimize false positives). Implementation of these components, in priority order (vs. workflow order), should be: test suite (obviously nothing else matters if there is no testing), vulnerability management, orchestration, and remediation management.

(U) An analysis was done to identify candidate test suite tools that lend themselves to upstream/downstream interoperation to maximize DevOps pipeline testing automation. The upstream tool providing orchestration for NGA's DevOps pipeline, is Jenkins. The downstream tool under consideration providing vulnerability management is ThreadFix. Following the implementation priority order prescribed above, the first consideration is test suite tools that integrate with ThreadFix.

(U) Table 4 contains ThreadFix scanner integrations with corresponding Jenkins plug-ins. Tools that integrate with both would be considered preferable at least from an automation perspective. Functionality and behavior of all integrations must tested and verified.

Table 4: (U) ThreadFix Scanner Integrations with Corresponding Jenkins Plug-ins

ThreadFix Scanner Integration	Jenkins Plug-in
Dependency Check	
OWASP Dependency Check	OWASP Dependency-Check Plugin – This plugin can analyze dependencies and generate trend reports for OWASP dependency check, an open source utility that detects known vulnerabilities in project dependencies.
Sonatype Nexus	Nexus Task Runner Plugin – This plugin executes Sonatype Nexus scheduled tasks after your build.
Dynamic Scanners	
Acunetix Web Vulnerability Scanner	
Arachni	
HPE Security WebInspect	
IBM AppScan Standard/Enterprise	
Mavituna Security Netsparker	
OWASP ZAP	Zapper Plugin — Zapper is a Jenkins Continuous Integration system plugin that helps you run OWASP ZAP as part of your automated security assessment regime. The plugin can use a pre-
	installed version of ZAP when given the path to the ZAP installation. Alternatively, it can automatically download and build a version of ZAP to be used by your security tests.
Portswigger BurpSuite Pro	
Qualys Web Application Scanning	
Rapid7 AppSpider	Appspider Build Scanner Plugin — The Appspider plugin allows you to configure settings to automatically trigger Appspider scans when builds of your web application completes. This enables your team to find web security defects earlier in the software development lifecycle.
Skipfish	
Tenable Nessus	
Trustwave App Scanner Enterprise	
Veracode Dynamic Analysis	
W3AF	
WhiteHat Security Sentinel (Dynamic)	
Interactive Scanners	
Contrast IAST Scanner	
Static Scanners	
Brakeman	Brakeman Plugin — This plugin reads output from Brakeman, a static analysis security vulnerability scanner for Ruby on Rails.
Checkmarx's CxSAST	Checkmarx CxSAST Plugin — This plugin adds an ability to perform automatic code scan by Checkmarx server and shows results summary and trend in Jenkins interface.
FindBugs	FindBugs Plugin — This plugin generates the trend report for FindBugs, an open source program which uses static analysis to look for bugs in Java code.
HPE Security Fortify	Jenkins only lists a plug-in for Fortify On Demand (a SaaS product), but HP asserts that NGA's in-house enterprise Fortify product does integrate with Jenkins.
IBM AppScan Source	IBM AppScan Source Scanner Plugin — Execute application scans with IBM Security AppScan Source
Veracode Binary Static Analysis	Veracode Scanner Plugin — This plugin provides a post build action for submitting files for scanning to veracode.
Virtual Forge CodeProfiler	
WhiteHat Security Sentinel (Static)	

(U) Figure 8 represents graphically the information in Table 4 above, and adds where stand-alone test tools and remediation management fit in the overall scheme. Remediation management is provided by Jira. ThreadFix has in-built Jira integration support. Four test tools are indicated as a Minimum Scan Requirement (highlighted in red; one in each category of dynamic test, static test, package dependency, and code quality). They were selected based on existing NGA investment or due to their combination of capability, maturity, and availability.

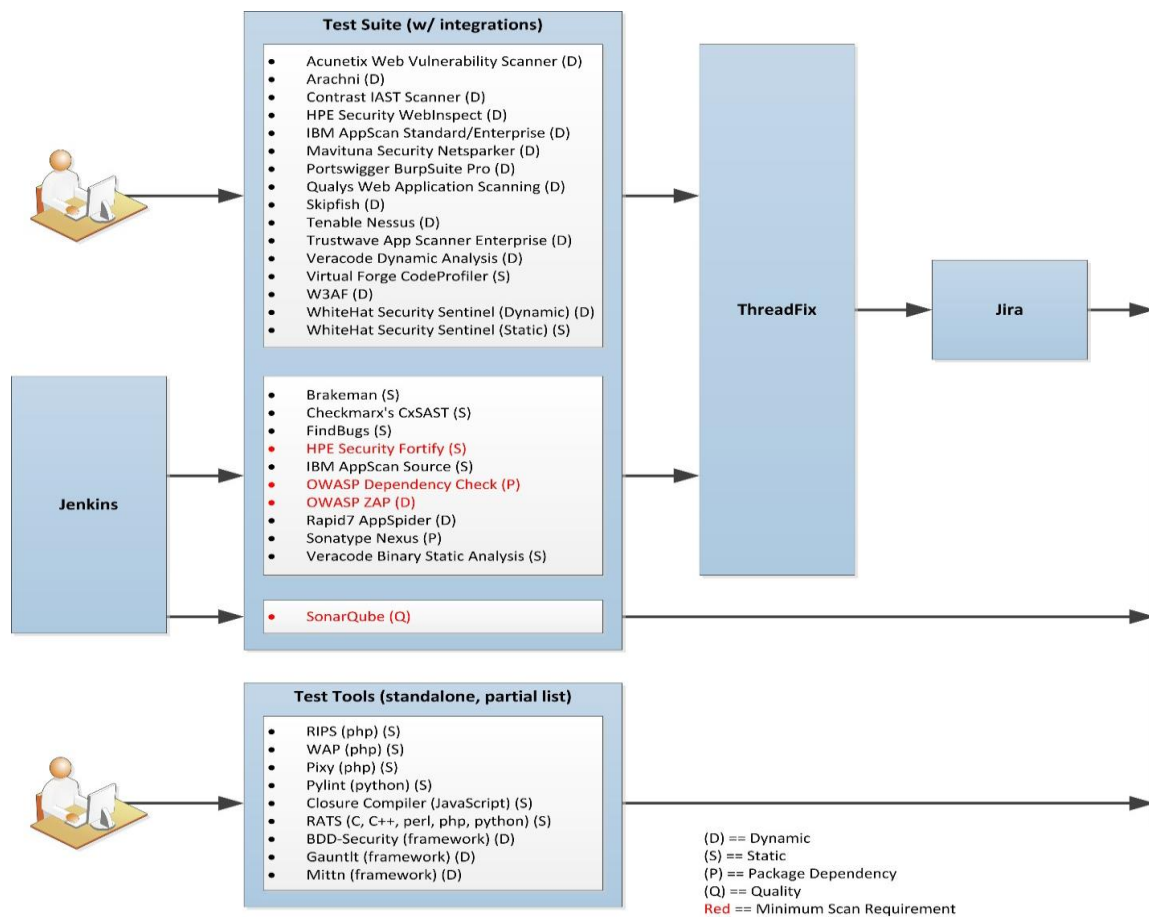


Figure 8: (U) DevOps Software Security Testing Component Relationships

(U) Confidence in testing, and thus security of tested software, dictates a repeatable process. It is assumed that the prescribed test tools support the application's test requirements and the developer's work habits. This may not always be the case. For example, HP Fortify has broad multi-language support, but doesn't support all languages. Accordingly, there is flexibility in test tool selection. In the end, there must rigor in software testing.